

BSc (Hons) Computer Science with Software Engineering - Coventry University

NB6007CEM - Web API Development

S8

CrudAndPushPath



Day 4 PM - Build Session

Niranga Dharmaratna | niranga@nibm.lk



ARC CLOSURE - S1 TO S8

**In Session 1 we stated the rule.
In Session 7 we designed the
enforcement.
This afternoon it becomes real.**

A device without the correct API key cannot push a ping. By the checkpoint, you will prove it.

Four Layers - 180 Minutes



Layer 1 - Member 404 (25 min)

GET /vehicles/:id returns 404 when the ID is not found. Collections always return 200 with an empty array.

Layer 2 - Push Path, X-API-Key Auth (55 min)

POST /vehicles/:id/pings with API-key auth. 401/403 split. Return 201 + Location + ETag + Last-Modified.

Layer 3 - Basic Auth on All GET Routes (35 min)

Middleware on every read endpoint. 401 + WWW-Authenticate if header absent. 403 if credentials wrong.

Layer 4 - Vehicle CRUD (30 min) - DROPPABLE

POST, PUT, DELETE on /vehicles. Drop to homework before compressing Layers 2 or 3.

Compression rule: Layer 4 to homework first. Never drop Layer 2 auth or Layer 3 WWW-Authenticate.

Before You Type a Line

Your REST client must prove it can reach your API before you add auth.

Make a GET /vehicles call. Does the response arrive? If yes, proceed. If no, fix the client first.

Gotcha: the browser address bar ignores custom headers. Use Postman, Insomnia, Thunder Client, or curl for all testing today.

curl - POST with X-API-Key header

```
curl -X POST \  
  https://your-api.onrender.com/vehicles/v-01/pings \  
  -H "X-API-Key: key_v01" \  
  -H "Content-Type: application/json" \  
  -d '{"latitude":6.93,"longitude":79.84,"speed":28}'
```

Expected response: 201 Created with Location header. If you see 200, your POST implementation is already wrong.

Route Reference Card

READ PATH - Basic Auth

- GET /provinces
- GET /provinces/:id
- GET /districts
- GET /districts/:id
- GET /stations
- GET /stations/:id
- GET /vehicles
- GET /vehicles/:id
- GET /vehicles/:id/pings
- **GET /vehicles/:id/pings/:pingId NEW**
- GET /vehicles/:id/last-position

WRITE + ADMIN PATH

WRITE - X-API-Key header

- POST /vehicles/:id/pings
201 + Location | 400 | 401 | 403 | 404

ADMIN - Basic Auth (Layer 4, DROPPABLE)

- POST /vehicles (201 + Location | 400 | 401)
- PUT /vehicles/:id (200 | 400 | 401 | 404)
- DELETE /vehicles/:id (200 | 401 | 404)

DEFERRED (not today)

- No PATCH. No write routes on pings.
- No write routes for Province, District, Station.

Layer 1 - Member 404 (25 min)

Collections always return 200 - never 404.

GET /vehicles with an empty vehicles array: respond 200, body []. An empty collection exists - it is not missing.

Members return 404 when the ID is not found.

GET /vehicles/v-99: if "v-99" is not in the vehicles array, respond 404.

Error body - define it once, apply it everywhere.

```
{ "error": "Vehicle not found" }
```

No auth yet. Prove all member routes return 404 correctly before moving to Layer 2.

Collections are never 404. Members can be. This rule applies to all six entity types.

Layer 2 - Push Path

Generate: POST /vehicles/:vehicleId/pings

```
Build deviceKeys = { "v-01": "key_v01", "v-02":  
"key_v02", ... }
```

Require X-API-Key header.

401 if header is absent

403 if key does not match deviceKeys[vehicleId]

404 if vehicleId not in vehicles array

400 if body missing latitude, longitude, or speed

```
Server sets timestamp: new Date().toISOString()
```

Push ping to array. Return 201.

```
Set Location:
```

```
/vehicles/:vehicleId/pings/:pingId
```

Set ETag and Last-Modified headers.

Before testing anything else: check your own status code.

401 - Header Absent

The X-API-Key header is missing. The device has not been identified. Client must re-send with the header.

403 - Key Wrong

Header present, key does not match deviceKeys[vehicleId]. Device identified but not authorised for this vehicle.

Arc Check - S7 Rule

S7 StatusInspector showed you: POST creates a resource. Your response must be 201, not 200. Location must resolve to a real URL.

Layer 3 - Read Auth (35 min)

Add a Basic Auth middleware to all GET routes.

Expected credentials: username "police", password "nibm2024".

Scoping boundary: police officers are read-only consumers. Write routes use X-API-Key. Do not apply Basic Auth there.

Generate prompt

Generate an Express basicAuth middleware that:

Reads the Authorization header. If absent: return 401 with WWW-Authenticate: Basic realm="Police API".

Decodes Base64 credentials. If username is not "police" or password is not "nibm2024": return 403.

Otherwise call next(). Apply this middleware to every GET route handler.

401 requires WWW-Authenticate. 403 does not. Critique: is the header present in your generated code?

Layer 4 - Vehicle CRUD (30 min)

DROPPABLE - move to homework if Layers 2 or 3 overran

- POST /vehicles - 201 + Location. Basic Auth. Validate id, plateNumber, vehicleType, stationId.
- PUT /vehicles/:id - 200. Whole-document replace, not partial. 404 if ID not found.
- DELETE /vehicles/:id - 200. Remove from array. Return the deleted vehicle in the body.
- Ping immutability: a deleted vehicle keeps its pings. Do not cascade-delete. Pings are audit records.

ANALOGY

Pings are the event log. Vehicles are the subject file. You can close a case file but you cannot redact the event log. Deletion is not erasure.

Generator Mistakes - All Layers



Layers 1 and 2

- Collection GET returns 404 (should be 200 + empty array)
- POST /pings returns 200 instead of 201
- Location header absent or path wrong
- ETag or Last-Modified header missing from 201 response
- 401 and 403 swapped (missing header vs wrong key)
- vehicleId existence not checked before auth middleware runs

Layers 3 and 4

- WWW-Authenticate header missing from 401 response
- Auth middleware registered after route handlers (order matters in Express)
- Basic Auth mistakenly applied to POST /vehicles/:id/pings (that route uses X-API-Key)
- DELETE /vehicles also deletes its pings (immutability violation)
- Server timestamp overwritten by a timestamp field in the device body

Day 4 Checkpoint



All items must be YES before you commit and redeploy.

- POST /vehicles/:id/pings returns 201 (not 200)
- Location header present and resolves to the correct ping URL
- Missing X-API-Key header returns 401; wrong key returns 403
- GET /vehicles without credentials returns 401 with WWW-Authenticate header
- GET /vehicles with Basic Auth (police:nibm2024) returns 200
- GET /vehicles/:id/pings/:pingId returns 200 or 404 correctly
- Committed and redeployed to Render - all routes responding

Fallback Prompt - CrudAndPushPath

Use this verbatim if you are still stuck after 20 minutes on any layer.

Build all of the following in your Express server:

1. POST /vehicles/:vehicleId/pings

Require X-API-Key. Build: deviceKeys = { "v-01": "key_v01", "v-02": "key_v02", ... }
Return 401 if header absent. Return 403 if key != deviceKeys[vehicleId].
Return 404 if vehicleId not found. Return 400 if body missing latitude, longitude, or speed.
Server sets timestamp: new Date().toISOString(). Push to pings array.
Return 201 + Location: /vehicles/:vehicleId/pings/:pingId + ETag + Last-Modified.

2. GET /vehicles/:vehicleId/pings/:pingId

Return 200 with ping object, or 404 if not found.

3. Basic Auth middleware on ALL GET routes

username: "police", password: "nibm2024"
Return 401 + WWW-Authenticate: Basic realm="Police API" if header absent.
Return 403 if credentials wrong. Apply middleware before each GET route handler.

Critique: Does POST return 201? Does Location resolve to a real URL?

Micro-Viva - Day 4

1. Why must POST /vehicles/:id/pings return 201 and not 200?
2. What is the difference between 401 and 403 in your push path?
3. Which header must accompany a 401 response, and why does the HTTP standard require it?
4. Your Location header reads /vehicles/v-01/pings/p-07. What resource does that URL identify?
5. Your partner deleted vehicle v-01. What happened to its pings, and why did you make that design choice?

Questions & Discussion

Checkpoint commits and redeploy before the end of the session.

Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I do make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 27 Jun 2026